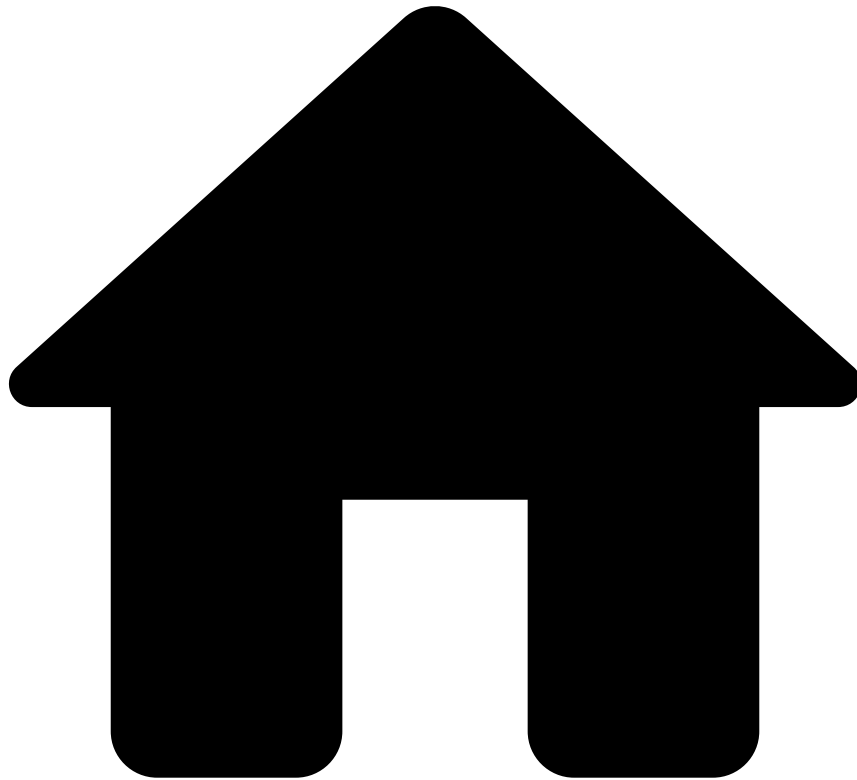


-



- [Technical Concepts](#)
- Two-Factor Authentication

On this page

Two-Factor Authentication

Two-Factor Authentication (**2FA**) is a functionality that improves security by requiring users to sign in with two pieces of information, also referred to as factors, to verify user identity.

In Case Manager, the user is prompted with a sign in form to enter its credentials (i.e. user account and password), followed by a second separate step in which the user has to provide a security code.

2FA creates a more secure authentication system while complying with PCI-DSS security standards.

What is 2FA?[🔗](#)

There are three factors that can be selected for user authentication:

- **Knowledge factor:** Comprises an information that the user knows. For example, a user password, or a numeric code such as personal identification number (PIN) used in ATMs.
- **Possession factor:** Comprises an information that the user has. For example, physical credit card, key fob that generates tokens, or a mobile device. The use of mobile devices as a possession factor has become increasingly popular. There are currently different approaches including sending a code by message or email to the user, or generating the code dynamically using a code generator application.
- **Biometric factor:** Comprises an information related to a human characteristic. For example, fingerprint or retinal scan.

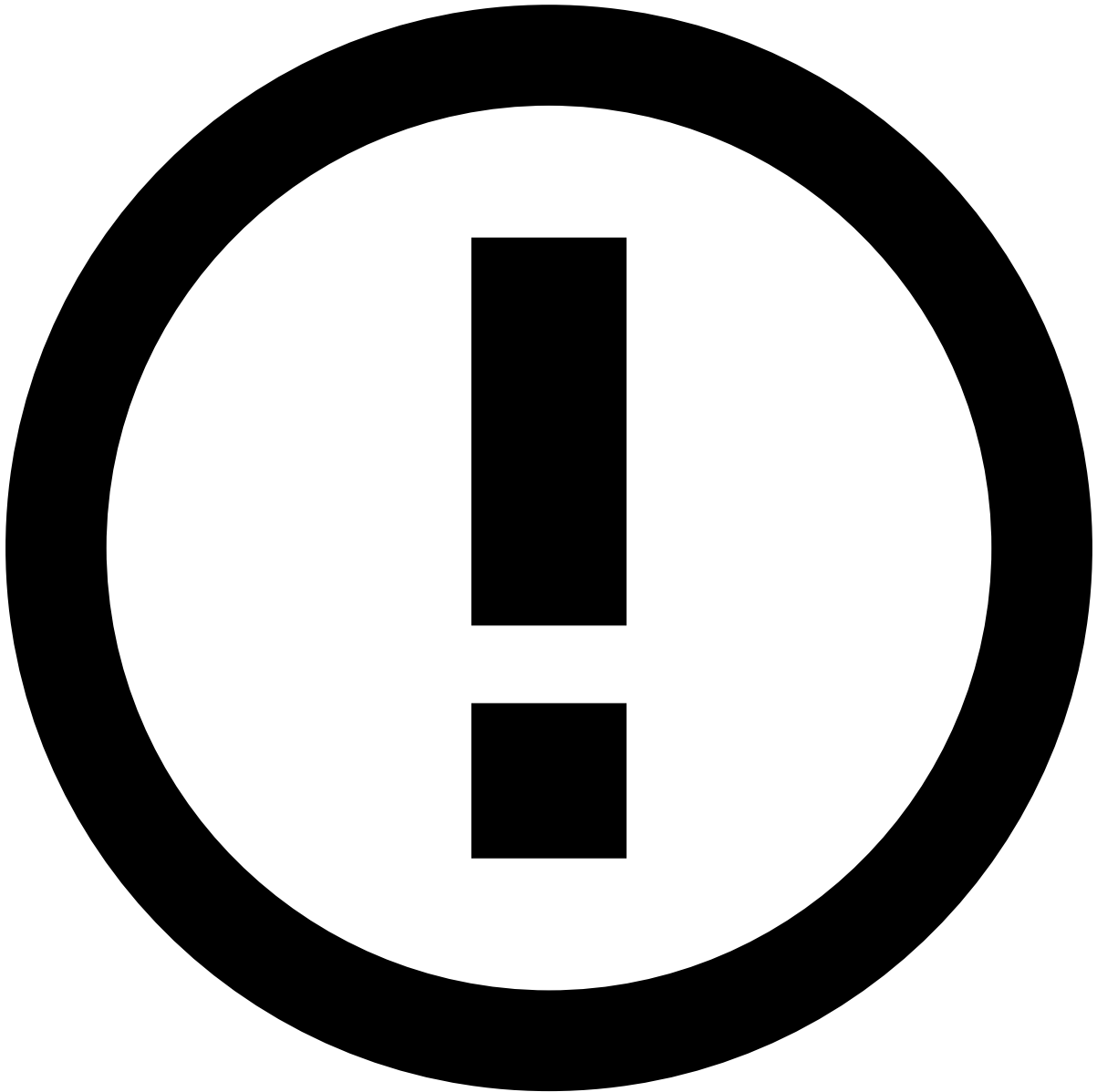
In a **2FA** approach, two out of the three factors are implemented to request user information in separate steps. Note that **2FA** is only valid if the two factors are distinct. For example, a typical scenario in which **2FA** is applied is when a person withdraws cash from an ATM. In this scenario, a person needs a credit card (i.e. possession factor) and a PIN code (i.e. knowledge factor).

2FA in Case Manager[🔗](#)

In Case Manager, **2FA** uses the knowledge and the possession factors. To sign in to Case Manager with **2FA** the user has to complete the following steps:

1. The user is prompted with a sign in form to enter Username and Password.
2. The user is prompted with another sign in form to enter a code generated by time-based one-time password (TOTP). Step 2 always follows Step 1.

Case Manager acts as a proxy, and thus, the User authentication including the validation of the code generated by TOTP is performed by Pulse. See the next subsection for further details of the TOTP.



Users with Single Sign-On

Users with [Single Sign-On](#) enabled are not covered by Case Manager **2FA**. In this case, user authentication is fully processed by the Identity Provider. Clients may still configure **2FA** depending on a policy of the Identity Provider.

Time-based One Time Password in Case Manager

The TOTP is an algorithm that is agnostic to the application which enables clients to use any code generator that they might already be using for authentication purposes, such as Google Authenticator. TOTP is a hash-based message authentication code (HMAC) that applies an algorithm to calculate a temporary code which is then used in the sign in process for authentication. Check the [RFC](#) page to learn more about the TOTP algorithm.

The code is generated based on a shared key between the user's device(s) and the entity responsible for User Authentication, and based on a time factor (i.e. comprising a time value and a time interval). Regarding the shared code, Case Manager acts as a proxy and delegates the process of User authentication to Pulse. Therefore, the user inserts the

code on Case Manager sign in form, then the code is redirected to Pulse, and it has to match the code expected by Pulse. Regarding the time factor, there are two important considerations:

- **Time value:** This approach relies on assumption that the user device, Case Manager and Pulse are configured with Network time protocol (NTP) so that the time is synchronized. Time synchronization is key in TOTP so that the code generated by the device matches the code expected by the sign in system at a given time.
- **Time interval:** This is the time during which the code is valid. Pulse uses 30 seconds intervals, which is the time recommended by RFC.

To account for network latency, slightly out-of-sync clocks and user time delay to insert the code, an extended time interval is generally configured beyond the time interval. The limits of the extended time interval can be set both forward and backward in relation to the timestamp on receipt of the TOTP value. Pulse follows a typical practice in the industry and the limit interval comprises the present 30 seconds interval, one interval before and one interval after.

Validation of 2FA in Case Manager

After the user completes Step 2 of the **2FA** sign in, the system verifies if the information inserted by the user (i.e. Username/Password/Code) is correct. If the information in Step 1 and/or Step 2 is not correct, the user is not granted access to a Case Manager session.

One important aspect in the case of authentication failure is that the system does not provide information to which step the user failed. This is a **2FA** requirement to comply with PCI-DSS security standards. Consequently, the number of maximum sign in trials with **2FA** applies to Username/Password/Code, i.e. the full sign in process comprised of Step 1 and Step 2.

Configuring 2FA

To sign in with **2FA**, an application that uses TOTP has to be configured on the user mobile device(s). Case Manager is agnostic to the application used to generate the code. The instructions to configure **2FA** on a user device using Google Authenticator as an example are provided in page [Configuring Two-Factor Authentication](#) in the User's Guide.

Resetting 2FA

The user might want to re-configure **2FA** due to lost of the device or deletion of the **2FA** configuration by accident. To reset the **2FA** configuration in Case Manager, the user has to have the reset key that is provided during **2FA** configuration. The reset key can be inserted in the second sign in step. Check the User's Guide to learn how to [reset 2FA configuration](#).

Resetting **2FA** of users without the reset key can only be performed by administrators through Pulse UI.

Learn More

To gain a practical knowledge on the **2FA** check the following sections in the User's Guide:

- [Configuring Two-Factor Authentication](#)
- [Resetting Two-Factor Authentication](#)